Luna Bags Network Security Hardening Report

Prem Kumar Santhanam

05/03/2025

Executive Summary

Luna Bags has implemented a robust firewall on its router using iptables to protect its internal corporate network. This firewall serves as the first line of defense, *segregating the public-facing DMZ* from the trusted internal network and filtering traffic between all network zones. By *default-denying all unsolicited connections*, the configuration ensures that only explicitly permitted traffic is allowed through, significantly reducing the organization's exposure to cyber threats. The firewall mitigates a range of threats including unauthorized access attempts, network scans, and certain types of Denial-of-Service (DoS) attacks. It achieves this by enforcing strict network segmentation isolating the DMZ from internal systems, allowing only necessary services (e.g., Web and VPN), and dropping or limiting suspicious traffic. As a result, Luna Bags internal resources are covered from direct internet exposure, and the risk of attackers breaching the internal network via the DMZ or other vectors is minimized in a larger scale.

This firewall configuration aligns with industry best practices by using a *"default drop"* security posture where only known, necessary traffic is allowed and everything else is blocked. It employs stateful inspection, where traffic for legitimate connections is automatically allowed while unexpected packets are discarded. The setup also includes advanced safeguards such as *intrusion scan protection* and *connection rate limiting* on the web server to blunt the impact of flooding attacks. In summary, the firewall significantly hardens Luna Bags network, creating a secure environment that protects critical data and systems while still permitting essential business connectivity.

Introduction

Luna Bags is a young fashion company that produces eco-friendly handbags and backpacks. The company started last year and has about 20 employees in its New York office and some remote workers. As the business grows, LB's IT infrastructure must remain secure to protect sensitive data like finance, customer info, HR records, etc. and ensure reliable operations. The IT Director, Louisa, has hired our team to implement cybersecurity measures to harden the company's network against attacks.

This report documents the process and results of securing LB's network based on the latest findings from our assessment. We first give an overview of the network topology, and the services discovered during our initial scanning. Next, we detail the installation of a public-facing Apache web server in the DMZ and verify its operation. We then designed a firewall policies, along with the specific iptables rules configured on the network's router to enforce that policy.

Network Overview

Luna Bags network is divided into distinct zones to enforce security boundaries. The primary zones include the **External (Internet)**, the **DMZ** (demilitarized zone for public-facing services), the **Internal Network** (trusted corporate LAN), and a **VPN Subnet** for remote users. This segmented design ensures that each zone's traffic can be controlled and monitored.

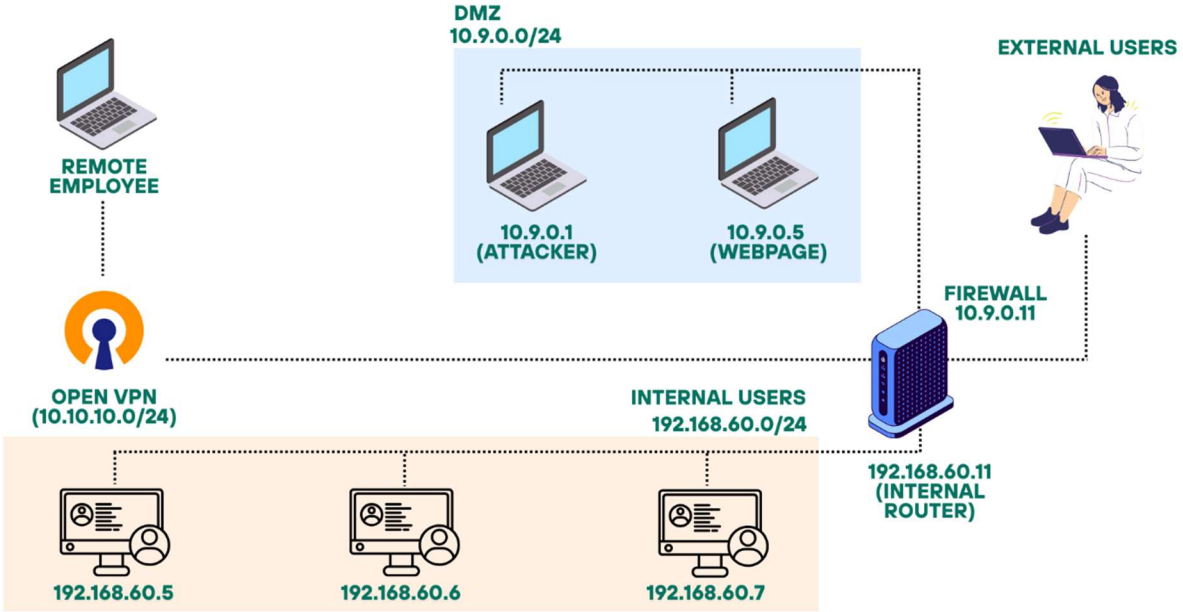

Fig:1 Network Topology

Luna Bags network is divided into four distinct zones—External, DMZ, Internal, and VPN—each protected by firewall rules that enforce strict segmentation. The **External network** is treated as untrusted, with only HTTP traffic to the DMZ permitted, while all other inbound traffic, including ping requests, is dropped to minimize exposure. The **DMZ (10.9.0.0/24)** hosts public-facing services like the web server and acts as a buffer zone; it allows limited communication with the internal network, ensuring that even if compromised, attackers cannot reach internal resources. The **Internal network (192.168.60.0/24)** is Luna Bag's secure LAN, completely isolated from the internet along with some exceptions for internal employees, with outbound access and controlled access to the DMZ, maintaining a strong internal defense. Lastly, the **VPN subnet (10.10.10.0/24)** allows secure remote access, treating authenticated VPN users as internal clients while routing all their traffic through the corporate firewall. This architecture enforces a least-

privilege model, ensuring that only business-critical traffic flows between zones, significantly reducing the risk of lateral movement or external compromise.

Firewall Architecture and Rule Explanation

The firewall configuration on the Luna Bags router is structured into categories of rules, each governing traffic between specific zones or handling particular types of traffic. At a high level, the firewall is set to "**deny by default**" – any traffic not explicitly allowed in these rules will be blocked. The rules below are processed in order, and they apply to the router's main firewall *chains*: **INPUT**, **FORWARD** and **OUTPUT**. *Refer Table 1* for the Firewall rules applied.

External → DMZ Traffic:

Only HTTP (port 80) from the internet to the DMZ web server (10.9.0.5) is allowed using a specific FORWARD rule. All other ports, protocols, and services are logged and dropped, preventing attackers from probing other services in the DMZ. This follows the principle of least privilege, exposing only what's necessary.

Internal → DMZ Traffic:

Internal users (192.168.60.0/24) can access the DMZ for HTTP (80) and SSH (22) using specific rules. This supports web testing and administrative SSH access without opening DMZ services to the public. Any non-approved traffic, like Telnet, is dropped by default.

Internal → Internet (Outbound) Traffic:

Internal hosts are allowed to initiate outbound internet connections for browsing, email, etc., via a general rule allowing new sessions to 0.0.0.0/0. This is complemented by stateful inspection, allowing return traffic seamlessly.

NAT for Internal Outbound Traffic:

The router performs NAT masquerading on outbound traffic (MASQUERADE), allowing internal private IPs to access the internet while hiding internal addressing from external entities. This is essential for internet connectivity and enhances privacy.

HTTPS Access Rule:

A specific rule also permits outbound HTTPS (port 443) from internal users. While somewhat redundant due to the general outbound rule, it reinforces the allowance of secure web browsing. Luna Bags may further refine this if access control policies evolve.

DMZ → Internal Traffic:

The firewall blocks all new connections initiated by the DMZ to the internal network. This ensures that even if a DMZ host is compromised, it cannot reach internal resources. Only reply traffic (e.g., SSH session responses) is allowed through stateful tracking.

VPN Access (Remote VPN Clients ↔ Internal Network)

Luna Bags firewall securely enables remote access by allowing VPN connections on **UDP port 1194** to the router's internal IP (192.168.60.1), using the rule, *refer table 1*. Once connected, VPN clients on the 10.10.10.0/24 subnet are permitted to communicate with internal resources (192.168.60.0/24) via bidirectional FORWARD rules, allowing seamless access to file servers, printers, and other services as if the user were on-site. Additionally, the firewall supports full-tunnel VPN functionality by applying **NAT masquerading**, that enables VPN clients to access the internet through the corporate gateway. This ensures their traffic is filtered and monitored like any internal user, improving security on untrusted networks. By restricting access

to a defined subnet and enforcing encryption and authentication, this setup aligns with best practices for secure and manageable remote access.

Management Access (SSH to Router, ICMP Ping)

The firewall configuration permits secure **SSH access** to the router exclusively from the internal network (192.168.60.0/24), allowing IT administrators to manage firewall, VPN, and routing settings without exposing this sensitive service to external or DMZ sources. Additionally, **ICMP echo (ping)** requests are allowed from internal and optionally from DMZ hosts to their respective router interfaces for basic network diagnostics. This controlled use of ping supports troubleshooting without weakening security, as external ICMP requests are blocked, and all replies are governed by stateful inspection.

Stateful Connection Tracking (Established/Related Traffic)

Luna Bags firewall uses **stateful inspection**, allowing return traffic for established and related connections using iptable rules, *refer table 1*. This enables secure two-way communication without requiring duplicate rules. Packets that don't match a valid connection, such as stray XMASs or FINs are dropped, enhancing protection against spoofed or malformed traffic. This mechanism ensures only legitimate, session-based traffic is allowed, reducing risk and simplifying rule management.

Dropping Invalid or Malicious Packets

The firewall uses connection tracking to identify and drop packets marked as **INVALID**, which often represent malformed, spoofed, or out-of-sequence traffic. These are logged with the prefix "**DROP INVALID:**" and provide valuable insights into potential attacks or network

misconfigurations. This rule, *refer table 1*, adds an extra layer of protection against non-standard or malicious traffic.

Null, Xmas, and FIN Scan Protection:

The firewall blocks stealth scanning techniques—Null, Xmas, and FIN scans—by detecting specific TCP flag patterns and dropping such packets immediately. This prevents attackers from using these methods to discover open ports, making Luna Bags network appear "filtered" and significantly harder to map or target.

Rate Limiting on Web Server:

A rule caps concurrent connections to port 80 at 100 per IP, rejecting further attempts to prevent simple DoS or abuse. This rate-limiting protects server resources from being overwhelmed by excessive connections from a single source while maintaining performance for legitimate users.

Default DROP Policy:

The firewall applies a strict default deny policy (*iptables -P FORWARD DROP*) for all traffic not explicitly permitted. This ensures that any unforeseen or misconfigured services are automatically blocked, enforcing strong access control and minimizing risk from unanticipated vulnerabilities.

Attack Simulation and Validation

To verify that the firewall is indeed providing the intended protection, we performed a series of tests simulating both malicious attacks and legitimate traffic. Below we outline each test scenario, the method used, and the observed result, demonstrating that the firewall rules are effective.

Simulated Attacks (Blocked Traffic)

Null Scan

We performed a Null scan (nmap -sN) against the DMZ web server, which sends TCP packets with no flags. The firewall's Null scan rule dropped these silently. Nmap reported all ports as "filtered" or "open|filtered," confirming that the firewall successfully blocked the scan and concealed open ports. *Refer fig 2*.

Xmas Scan

An Xmas scan (nmap -sX) was launched, sending TCP packets with FIN, PSH, and URG flags. The firewall's explicit rule targeting this flag combination effectively blocked the packets. Nmap could not determine the status of any ports, verifying that the firewall prevented reconnaissance attempts. *Refer Fig 2*.

Fin Scan

We executed a FIN scan (nmap -sF), which sends TCP packets with only the FIN flag. Although not explicitly blocked, these were dropped by the firewall's stateful inspection as they lacked a proper SYN handshake. All ports appeared filtered, confirming that the firewall blocked the scan based on connection state. *Refer Fig 2*.

DMZ to Internal Access Attempt

To validate internal network protection, we attempted to connect from the DMZ server to an internal host on random ports, but all attempts failed as expected, *Refer Figure 8*. The firewall logged these as **"FW DROP DMZ->INT"** confirming that DMZ-initiated traffic to the internal LAN is effectively blocked, preventing lateral movement even if the DMZ is compromised. Additionally, we conducted external Nmap scans targeting ports other than HTTP (80) and VPN

(1194) on the DMZ server, and all were shown as "filtered." Attempts to access closed ports (e.g., port 81) or internal IPs (e.g., 192.168.60.5) were also silently dropped. These results confirm that only explicitly allowed services are accessible externally, while everything else remains hidden and unreachable—ensuring a strong, locked-down perimeter.

Blocked Traffic Tests (Simulation of Attacks and Unauthorized Access)

Telnet/FTP from External to DMZ: Attempted to connect to DMZ server on ports 21 and 23 from the internet, were dropped silently. Logs confirmed "**FW DROP EXT->DMZ**" entries, validating firewall enforcement.

DMZ to Internal FTP Attempt: DMZ server tried to initiate FTP to internal host, which failed. The connection was blocked and logged as "**FW DROP DMZ->INT**", confirming strict internal network protection.

Internal Telnet to DMZ: An internal client tried Telnet to 10.9.0.5 (port 23), which timed out. Only SSH and HTTP are permitted to DMZ, proving the firewall's service-specific rules.

DMZ to Internal HTTP Probe: A DMZ host tried to access internal HTTP services and was blocked. The attempt was logged, confirming the firewall's **DMZ-to-Internal isolation** is working.

External Access to Unauthorized Ports: Nmap scans from external sources (except port 80) returned "filtered." Attempts to access ports like 22, 81, and 3389 received no response, proving stealth protection.

Allowed Traffic Tests (Legitimate Business Connectivity)

External Access to DMZ Web Server: HTTP requests from external users to the public web server (10.9.0.5) succeeded. Verified using curl and logs showing accepted port 80 connections.

Internal Access to DMZ Web Server: HTTP requests from internal clients to the public web server (10.9.0.5) succeeded. Verified using curl and logs showing accepted port 80 connections.

Internal SSH to DMZ and Router: SSH from internal hosts to DMZ (10.9.0.5) and router (192.168.60.1) was successful. Admin access worked, while SSH from DMZ was denied, as expected.

Additional Hardening Measures in the Configuration

Luna Bags has implemented several advanced hardening measures that significantly enhance the security and resilience of its firewall setup. The configuration adopts a **default DROP policy**, which blocks all unsolicited traffic unless explicitly permitted, reducing the risk of exposed services and making the network less visible to automated scans. **Stateful inspection** is used to allow only valid return traffic, ensuring that unauthorized or malformed packets are dropped, offering basic protection against certain DoS attempts. The firewall also includes detailed **logging of dropped packets**, enabling the security team to monitor for suspicious activity and respond quickly to potential threats.

Additionally, **anti-scan rules** proactively block stealthy reconnaissance techniques like Null, Xmas, and FIN scans, helping to hide open ports from attackers. A **rate-limiting** rule on port 80 restricts the number of concurrent connections per IP, preventing a single host from overloading the web server. The router itself is hardened by running only essential services, with unnecessary

ports (like HTTP or SNMP) disabled to reduce the attack surface. Furthermore, **NAT combined with private IP addressing** ensures that internal systems are not directly reachable from the outside, adding both network segmentation and obscurity. Collectively, these measures form a **defense-in-depth strategy** that not only blocks common threats but also provides administrators with visibility and control to detect and respond to more sophisticated attacks early.

Maintenance and Future Recommendations

To sustain its strong security posture, Luna Bags should **regularly audit firewall rules** to align with evolving business needs and remove outdated entries. **Log monitoring** with alerts or SIEM integration is crucial for spotting anomalies like excessive “DROP INVALID” entries. All systems, including the router and web servers, must be **kept patched** to guard against known vulnerabilities. As traffic scales, **additional throttling** using iptables modules can help mitigate abuse. Strong **VPN security**, with multi-factor authentication and access reviews, is vital due to its direct link to internal resources. Finally, **periodic penetration testing** should be conducted to validate and enhance the firewall's resilience against real-world threats.

Conclusion and Recommendations

The firewall configuration at Luna Bags demonstrates several key successes that collectively strengthen the company’s security posture. One of the most important achievements is robust network segmentation, where the DMZ isolates public-facing services from the internal network, ensuring that only the web server is reachable from the internet while critical internal assets remain shielded and inaccessible. The setup also achieves controlled access for business operations, enabling seamless functionality for customers, remote employees via VPN, and internal IT staff, without exposing unnecessary or risky services. Additionally, the firewall

incorporates proactive security measures, such as scan detection and connection rate-limiting, which help identify and block common attack patterns used during early stages of cyber intrusions. Comprehensive logging and monitoring of dropped traffic provides visibility into potential threats, empowering the security team to detect and respond to suspicious activity swiftly. Finally, the entire configuration adheres to recognized industry best practices, with a default-deny approach, stateful packet inspection, and a lean router surface that only runs essential services demonstrating a strong, strategic security design.

Finally, Luna Bag's firewall setup is well-designed, balancing security with usability. With layered defenses and strict access control, it safeguards critical systems while supporting daily operations. Continued maintenance will ensure long-term resilience against evolving cyber threats.

Working Evidences

```
root@97fbcfe7d07a:/# nmap -sN -p 1-100 10.9.0.5
Starting Nmap 7.80 ( https://nmap.org ) at 2025-05-01 21:54 UTC
Nmap scan report for 10.9.0.5
Host is up (0.00023s latency).
All 100 scanned ports on 10.9.0.5 are open|filtered

Nmap done: 1 IP address (1 host up) scanned in 1.95 seconds
root@97fbcfe7d07a:/# nmap -sX -p 1-100 10.9.0.5
Starting Nmap 7.80 ( https://nmap.org ) at 2025-05-01 21:55 UTC
Nmap scan report for 10.9.0.5
Host is up (0.00020s latency).
All 100 scanned ports on 10.9.0.5 are open|filtered

Nmap done: 1 IP address (1 host up) scanned in 1.88 seconds
root@97fbcfe7d07a:/# nmap -sF -p 1-100 10.9.0.5
Starting Nmap 7.80 ( https://nmap.org ) at 2025-05-01 21:56 UTC
Nmap scan report for 10.9.0.5
Host is up (0.00013s latency).
All 100 scanned ports on 10.9.0.5 are open|filtered

Nmap done: 1 IP address (1 host up) scanned in 1.90 seconds
root@97fbcfe7d07a:/#
```

Fig 2: Nmap reported all ports as "filtered or open|filtered," with no actual open ports identified.

```
root@dba9befb84df:/volumes# iptables -L FORWARD -v -n --line-numbers
Chain FORWARD (policy DROP 0 packets, 0 bytes)
num   pkts bytes target     prot opt in     out     source               destination
1        0     0 ACCEPT     all  --  *      *       0.0.0.0/0            0.0.0.0/0            state RELATED,ESTABLISHED
2        0     0 ACCEPT     tcp  --  *      *       0.0.0.0/0            10.9.0.5             tcp dpt:80 state NEW
3        0     0 LOG        all  --  *      *       0.0.0.0/0            10.9.0.0/24          state NEW LOG flags 0 level 4 prefix "FW DROP E
XT->DMZ: "
4        0     0 DROP       all  --  *      *       0.0.0.0/0            10.9.0.0/24          state NEW
5        0     0 ACCEPT     tcp  --  *      *       192.168.60.0/24      10.9.0.5             tcp dpt:80 state NEW
6        0     0 ACCEPT     tcp  --  *      *       192.168.60.0/24      10.9.0.0/24          tcp dpt:22 state NEW
7        0     0 ACCEPT     all  --  *      *       192.168.60.0/24      0.0.0.0/0            state NEW
8        0     0 LOG        all  --  *      *       10.9.0.0/24          192.168.60.0/24      state NEW LOG flags 0 level 4 prefix "FW DROP D
MZ->INT: "
9        0     0 DROP       all  --  *      *       10.9.0.0/24          192.168.60.0/24      state NEW
10       0     0 ACCEPT     all  --  *      *       10.10.10.0/24        192.168.60.0/24      state NEW
11       0     0 ACCEPT     all  --  *      *       192.168.60.0/24      10.10.10.0/24        state NEW
12       0     0 ACCEPT     tcp  --  *      *       192.168.60.0/24      0.0.0.0/0            tcp dpt:443
13       0     0 LOG        all  --  *      *       0.0.0.0/0            0.0.0.0/0            state INVALID LOG flags 0 level 4 prefix "DROP
INVALID: "
14       0     0 DROP       all  --  *      *       0.0.0.0/0            0.0.0.0/0            state INVALID
15       0     0 DROP       tcp  --  *      *       0.0.0.0/0            0.0.0.0/0            tcp flags:0x3F/0x00
16       0     0 DROP       tcp  --  *      *       0.0.0.0/0            0.0.0.0/0            tcp flags:0x3F/0x3F
17       0     0 DROP       tcp  --  *      *       0.0.0.0/0            0.0.0.0/0            tcp flags:0x3F/0x29
18       0     0 REJECT     tcp  --  *      *       0.0.0.0/0            0.0.0.0/0            tcp dpt:80 #conn src/32 > 100 reject-with icmp-
port-unreachable
```

Fig 3:Ip Table

```
root@dba9befb84df:/volumes# ping 192.168.60.5
PING 192.168.60.5 (192.168.60.5) 56(84) bytes of data.
ping: sendmsg: Operation not permitted
ping: sendmsg: Operation not permitted
ping: sendmsg: Operation not permitted
ping: sendmsg: Operation not permitted
^C
--- 192.168.60.5 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3067ms
```

Fig:4: External to Internal Blocked

```
root@4627c75f6658:/# ping google.com
PING google.com (172.217.165.142) 56(84) bytes of data.
64 bytes from lax30s03-in-f14.1e100.net (172.217.165.142): icmp_seq=1 ttl=107 ti
me=30.5 ms
64 bytes from lax30s03-in-f14.1e100.net (172.217.165.142): icmp_seq=2 ttl=107 ti
me=30.7 ms
64 bytes from lax30s03-in-f14.1e100.net (172.217.165.142): icmp_seq=3 ttl=107 ti
me=24.5 ms
^C
--- google.com ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2006ms
rtt min/avg/max/mdev = 24.464/28.567/30.724/2.902 ms
root@4627c75f6658:/#
```

Fig 5: Internal to External Allowed

```
[05/01/25]seed@VM:~$ docksh 97fbcfe7d07a
root@97fbcfe7d07a:/# ping -c 4 192.168.60.1
PING 192.168.60.1 (192.168.60.1) 56(84) bytes of data.
64 bytes from 192.168.60.1: icmp_seq=1 ttl=64 time=0.137 ms
64 bytes from 192.168.60.1: icmp_seq=2 ttl=64 time=0.150 ms
64 bytes from 192.168.60.1: icmp_seq=3 ttl=64 time=0.183 ms
^C
--- 192.168.60.1 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2038ms
rtt min/avg/max/mdev = 0.137/0.156/0.183/0.019 ms
root@97fbcfe7d07a:/#
```

Fig 6: Internal ping to router-Attack simulation worked

```
[05/01/25]seed@VM:~$ curl http://10.9.0.5

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.or
g/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
  <!--
    Modified from the Debian original for Ubuntu
    Last updated: 2016-11-16
    See: https://launchpad.net/bugs/1288690
```

Fig 7: HTTP Access from External to DMZ (Allowed)

```
root@dba9befb84df:/volumes# ping 192.168.60.5
PING 192.168.60.5 (192.168.60.5) 56(84) bytes of data.
ping: sendmsg: Operation not permitted
ping: sendmsg: Operation not permitted
ping: sendmsg: Operation not permitted
ping: sendmsg: Operation not permitted
^C
--- 192.168.60.5 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3067ms
```

Fig 8: DMZ to Internal Blocked

```
root@09a379d3309b:/# nc -zv 192.168.60.100 22
nc: connect to 192.168.60.100 port 22 (tcp) failed: Connection timed out
```

Fig 9: Test internal network isolation from DMZ is blocked. Rule working

```
root@dba9befb84df:/# iptables -L FORWARD -v -n --line-numbers
Chain FORWARD (policy DROP 0 packets, 0 bytes)
num   pkts bytes target     prot opt in     out     source               destination
1     7859   42M ACCEPT     all  --  *      *       0.0.0.0/0            0.0.0.0/0            state RELATED,ESTABLISHED
2       13   520 ACCEPT     tcp  --  *      *       0.0.0.0/0            10.9.0.5             tcp dpt:80 state NEW
3       53  4032 LOG        all  --  *      *       0.0.0.0/0            10.9.0.0/24          state NEW LOG flags 0 level 4 prefix "FW DROP E
XT->DMZ: "
4       53  4032 DROP       all  --  *      *       0.0.0.0/0            10.9.0.0/24          state NEW
5        0     0 ACCEPT     tcp  --  *      *       192.168.60.0/24      10.9.0.5             tcp dpt:80 state NEW
6        0     0 ACCEPT     tcp  --  *      *       192.168.60.0/24      10.9.0.0/24          tcp dpt:22 state NEW
7       19  1269 ACCEPT     all  --  *      *       192.168.60.0/24      0.0.0.0/0            state NEW
8       10   672 LOG        all  --  *      *       10.9.0.0/24          192.168.60.0/24      state NEW LOG flags 0 level 4 prefix "FW DROP D
MZ->INT: "
9       10   672 DROP       all  --  *      *       10.9.0.0/24          192.168.60.0/24      state NEW
10       0     0 ACCEPT     all  --  *      *       10.10.10.0/24        192.168.60.0/24      state NEW
11       0     0 ACCEPT     all  --  *      *       192.168.60.0/24      10.10.10.0/24        state NEW
12       0     0 ACCEPT     tcp  --  *      *       192.168.60.0/24      0.0.0.0/0            tcp dpt:443
13     600 24000 LOG        all  --  *      *       0.0.0.0/0            0.0.0.0/0            state INVALID LOG flags 0 level 4 prefix "DROP
INVALID: "
14     600 24000 DROP       all  --  *      *       0.0.0.0/0            0.0.0.0/0            state INVALID
15       0     0 DROP       tcp  --  *      *       0.0.0.0/0            0.0.0.0/0            tcp flags:0x3F/0x00
16       0     0 DROP       tcp  --  *      *       0.0.0.0/0            0.0.0.0/0            tcp flags:0x3F/0x3F
17       0     0 DROP       tcp  --  *      *       0.0.0.0/0            0.0.0.0/0            tcp flags:0x3F/0x29
18       0     0 REJECT     tcp  --  *      *       0.0.0.0/0            0.0.0.0/0            tcp dpt:80 #conn src/32 > 100 reject-with icmp-
port-unreachable
root@dba9befb84df:/#
```

Fig 10: IP TABLE after testing

```
root@dba9befb84df:/# service apache2 start
 * Starting Apache httpd web server apache2
AH00558: apache2: Could not reliably determine the server's fully qualified domain na
me, using 192.168.60.11. Set the 'ServerName' directive globally to suppress this mes
sage
 *
root@dba9befb84df:/# service apache2 status
 * apache2 is running
root@dba9befb84df:/#
```

Fig 11: Apache2 Server Running

NMAP Scan Report

```
Nmap scan report for c6f19d188fa0 (10.9.0.5)
Host is up (0.0000030s latency).
Not shown: 65533 closed ports
PORT   STATE SERVICE VERSION
23/tcp open  telnet  Linux telnetd
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Nmap scan report for dba9befb84df (10.9.0.11)
Host is up (0.000011s latency).
Not shown: 65534 closed ports
PORT   STATE SERVICE VERSION
23/tcp open  telnet  Linux telnetd
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Nmap scan report for host1-192.168.60.5.net-192.168.60.0 (192.168.60.5)
Host is up (0.0000070s latency).
Not shown: 999 closed ports
PORT   STATE SERVICE VERSION
23/tcp open  telnet  Linux telnetd
MAC Address: 02:42:C0:A8:3C:05 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Nmap scan report for host2-192.168.60.6.net-192.168.60.0 (192.168.60.6)
Host is up (0.0000070s latency).
Not shown: 999 closed ports
PORT   STATE SERVICE VERSION
23/tcp open  telnet  Linux telnetd
MAC Address: 02:42:C0:A8:3C:06 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Nmap scan report for host3-192.168.60.7.net-192.168.60.0 (192.168.60.7)
Host is up (0.000010s latency).
Not shown: 999 closed ports
PORT   STATE SERVICE VERSION
23/tcp open  telnet  Linux telnetd
MAC Address: 02:42:C0:A8:3C:07 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Nmap scan report for dba9befb84df (192.168.60.11)
Host is up (0.0000030s latency).
Not shown: 65534 closed ports
PORT   STATE SERVICE VERSION
23/tcp open  telnet  Linux telnetd
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
root@dba9befb84df:/# nmap -sV 192.168.60.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2025-04-30 22:58 UTC
Nmap scan report for 192.168.60.1
Host is up (0.0000060s latency).
Not shown: 995 closed ports
PORT   STATE SERVICE VERSION
7/tcp  open  echo
19/tcp open  chargen Linux chargen
21/tcp open  ftp     vsftpd 3.0.3
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
23/tcp open  telnet  Linux telnetd
MAC Address: 02:42:EA:47:E6:75 (Unknown)
Service Info: OSs: Linux, Unix; CPE: cpe:/o:linux:linux_kernel
```

Firewall Rule Implemented

```
Terminal
  I A    [~/final/volumes/luna_firewall_rules.sh] (sh)                    Row 1    Col 1    9:17  ^X^H for help

#!/bin/bash

# Flush existing rules
iptables -F
iptables -X
iptables -Z

# Set default policies
iptables -P FORWARD DROP
iptables -P INPUT DROP
iptables -P OUTPUT DROP

# Allow established and related connections
iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
iptables -A FORWARD -m state --state ESTABLISHED,RELATED -j ACCEPT

# Allow HTTP from external to DMZ web server (10.9.0.5)
iptables -A FORWARD -s 0.0.0.0/0 -d 10.9.0.5 -p tcp --dport 80 -m state --state NEW -j ACCEPT

# Block and log all other external -> DMZ traffic
iptables -A FORWARD -s 0.0.0.0/0 -d 10.9.0.0/24 -m state --state NEW -j LOG --log-prefix "FW DROP EXT->DMZ: "
iptables -A FORWARD -s 0.0.0.0/0 -d 10.9.0.0/24 -m state --state NEW -j DROP

# Allow internal to DMZ HTTP and SSH
iptables -A FORWARD -s 192.168.60.0/24 -d 10.9.0.5 -p tcp --dport 80 -m state --state NEW -j ACCEPT
iptables -A FORWARD -s 192.168.60.0/24 -d 10.9.0.0/24 -p tcp --dport 22 -m state --state NEW -j ACCEPT

# Allow internal to external (Internet) traffic
iptables -A FORWARD -s 192.168.60.0/24 -d 0.0.0.0/0 -m state --state NEW -j ACCEPT

# NAT for internal to external (Internet)
iptables -t nat -A POSTROUTING -s 192.168.60.0/24 -j MASQUERADE

# Block and log DMZ to internal traffic
iptables -A FORWARD -s 10.9.0.0/24 -d 192.168.60.0/24 -m state --state NEW -j LOG --log-prefix "FW DROP DMZ->INT: "
iptables -A FORWARD -s 10.9.0.0/24 -d 192.168.60.0/24 -m state --state NEW -j DROP
```

```
# Allow internal SSH to router
iptables -A INPUT -s 192.168.60.0/24 -d 192.168.60.11 -p tcp --dport 22 -m state --state NEW -j ACCEPT

# Allow ping from internal to router
iptables -A INPUT -s 192.168.60.0/24 -d 192.168.60.11 -p icmp --icmp-type echo-request -m state --state NEW -j ACCEPT

# Allow ping from DMZ to router (optional)
iptables -A INPUT -s 10.9.0.0/24 -d 10.9.0.1 -p icmp --icmp-type echo-request -m state --state NEW -j ACCEPT

# Allow VPN connections from remote clients to router VPN (e.g., OpenVPN on UDP 1194)
iptables -A INPUT -p udp --dport 1194 -d 192.168.60.11 -m state --state NEW -j ACCEPT

# Allow VPN clients to access internal network
iptables -A FORWARD -s 10.10.10.0/24 -d 192.168.60.0/24 -m state --state NEW -j ACCEPT
iptables -A FORWARD -s 192.168.60.0/24 -d 10.10.10.0/24 -m state --state NEW -j ACCEPT

# NAT VPN traffic out to Internet (if VPN clients should browse internet)
iptables -t nat -A POSTROUTING -s 10.10.10.0/24 -o eth0 -j MASQUERADE

# Internal to External on HTTPS for browsing
iptables -A FORWARD -s 192.168.60.0/24 -p tcp --dport 443 -j ACCEPT

# Log and Drop Invalid Packets
iptables -A FORWARD -m state --state INVALID -j LOG --log-prefix "DROP INVALID: "
iptables -A FORWARD -m state --state INVALID -j DROP

# Block Null, XMAS, and FIN scans
iptables -A FORWARD -p tcp --tcp-flags ALL NONE -j DROP
iptables -A FORWARD -p tcp --tcp-flags ALL FIN,URG,PSH -j DROP

# Rate Limiting on Apache2
iptables -A FORWARD -p tcp --dport 80 -m connlimit --connlimit-above 100 -j REJECT
```

Rule Category	Rule Implemented	Why ?	Outcome	PORT(S)	How It Helps ?
External to DMZ	ACCEPT TCP dport 80 to 10.9.0.5	Allow public HTTP access to web server	Customers can reach website	80 (HTTP)	Enables external users to browse the website
External to DMZ	DROP other new connections to 10.9.0.0/24	Block all unauthorized external access to DMZ	Scans or attacks on other DMZ ports are dropped	All except 80	Prevents access to non-web services in DMZ
Internal to DMZ	ACCEPT TCP dport 80 and 22 to 10.9.0.0/24	Allow internal users to browse/test and administer DMZ servers	Admin can SSH, users can test HTTP	22 (SSH), 80 (HTTP)	Supports internal maintenance and monitoring
DMZ to Internal	DROP all new connections from 10.9.0.0/24 to 192.168.60.0/24	Prevent lateral movement into internal network	DMZ hosts cannot initiate internal connections	All	Contain breach attempts within DMZ
Internal to Internet	ACCEPT NEW from 192.168.60.0/24 to 0.0.0.0/0	Allow internal users to browse the web	Internal clients have internet access	80, 443	Allows web and service access for users
VPN Access	ACCEPT VPN subnet to internal (10.10.10.0/24 -> 192.168.60.0/24)	Enable remote access to internal network	VPN clients can reach internal resources	All (controlled by internal services)	Supports secure work-from-home capabilities
Rate Limiting	REJECT if >100 TCP connections to port 80	Prevent DoS by limiting concurrent connections	Attackers get cut off; server stays available	80	Protects web server from overload
Scan Protection	DROP packets with null/XMAS/FIN flags	Detect and block stealth scans	Nmap and similar scans fail to enumerate open ports	All TCP	Reduces exposure to reconnaissance attacks
Stateful Inspection	ACCEPT ESTABLISHED,RELATED	Allow replies and related traffic	Legitimate connections function correctly	All Allowed	Ensures proper bi-directional communication
Invalid Packet Filtering	DROP INVALID packets	Prevent malformed/attack packets from entering	Spoofed or broken sessions are discarded	All	Enhances protocol sanity and security

Table 1: Rule Table

Attack Type	Command	Source	Target	Result	Firewall Behaviour
Null Scan	nmap -sN -p 1-100 10.9.0.5	External	DMZ Server (10.9.0.5)	All ports appear filtered	Drops packets with no TCP flags (Null scan protection)
XMAS Scan	nmap -sX -p 1-100 10.9.0.5	External	DMZ Server (10.9.0.5)	No ports revealed, filtered or open|filtered	Drops packets matching XMAS scan signature
FIN Scan	nmap -sF -p 1-100 10.9.0.5	External	DMZ Server (10.9.0.5)	Ports undetectable	Drops packets not part of valid session
Invalid ACK Packet	hping3 -A 10.9.0.5 -p 80	External	DMZ Server (10.9.0.5)	No response, logged as DROP INVALID	Prevents malformed TCP sessions
Telnet to DMZ	telnet 10.9.0.5 23	External	DMZ Server (10.9.0.5)	Connection times out or refused	Rejects unauthorized service access
DMZ to Internal Scan	nc -zv 192.168.60.100 22	DMZ Server	Internal Host	Connection fails	Blocks lateral movement
VPN Access to Internal	ssh internal@192.168.60.100	VPN Client (10.10.10.2)	Internal Host	Successful SSH session	Permits secure remote access
Web Access from External	curl http://10.9.0.5	External	DMZ Web Server	Web page loads	Allows customer web traffic

Table 2: Attack Table

References

Network Design Scenario #2: DMZ Design
https://www.networkdefenseblog.com/post/design-scenario-2-dmz-design#:~:text=The%20diagram%20highlights%20the%20simple,traffic%20towards%20the%20trusted%20network

How To Choose an Effective Firewall Policy to Secure your Servers| Digital Ocean
https://www.digitalocean.com/community/tutorials/how-to-choose-an-effective-firewall-policy-to-secure-your-servers

OpenVPN
Resources For OpenVPN OpenSource Community | OpenVPN

IPTABLES
netfilter/iptables project homepage - Documentation about the netfilter/iptables project